

AI Governance & Compliance Portfolio

FinanceGuard AI — Fine-Tuned Large Language Model, Hybrid Cloud Deployment

Prepared by: AI Governance Program Lead | Date: 8 July 2026

System Profile (Fixed)

System type	Fine-tuned large language model (LLM) performing automated review of legal and compliance documents.
Deployment environment	Hybrid cloud. Third-party cloud infrastructure accessed through an internal API gateway.
Data classification	Highly confidential. Processes personally identifiable information (PII) and confidential financial data.
User groups	Internal users only — compliance analysts and legal teams.
Governance scope	Outputs inform decisions on contract approvals and regulatory submissions.

Contents

Section 1 — Governance Accountability Summary — RACI matrix and executive sign-off memo

Section 2 — Policy Gap & Compliance Status — Responsible AI policy gap analysis and ISO/IEC 42001 control matrix excerpt

Section 3 — Audit Readiness Assessment — SOC 2 evidence review summary and CISO go/no-go recommendation

Section 4 — Policy Statements & Exception Record — AI model security and monitoring policy statements and exception decision record

Appendix A — ISO/IEC 42001 Compliance Control Matrix — Full six-control compliance baseline, including Clause 6.1.2

Section 1—Governance Accountability Summary

1. FinanceGuard AI: RACI Matrix

AI Lifecycle Phase/Activity	Executive Steering Committee	AI Program Lead/Governance Manager	Model Owner/Business Sponsor	Cyber Security & Legal Teams	External Audit Partners
System Selection & Model Fine-Tuning Approval	A	R	C	C	I
Data Privacy & PII Boundary Enforcement	I	C	R	A	I
API Gateway & Hybrid Cloud Deployment Oversight	I	C	A	R	I
Continuous Monitoring & Performance Review	I	A	R	C	C

Exception Identification & Framework Mitigation	A	R	C	C	I
--	----------	----------	----------	----------	----------

2. Executive Sign-Off Memo

To: Executive Steering Committee

From: AI Governance Program Lead

Date: July 8, 2026

Subject: FinanceGuard AI Governance Framework & RACI Sign-Off

This memorandum records the accountability structure approved for FinanceGuard AI, a fine-tuned large language model processing personally identifiable and confidential financial data within a hybrid cloud environment.

Two decisions warrant explanation. First, the Committee retains accountability for both fine-tuning approval and exception mitigation. Authorising a model to inform contract approvals and regulatory submissions constitutes acceptance of regulatory risk, and that acceptance cannot be delegated to the functions that build or operate the system. Second, accountability for PII boundary enforcement rests with Cyber Security and Legal rather than the Model Owner. The boundary is a statutory obligation before it is a technical control, and self-certification by the implementing team would compromise independent review.

One risk requires the Committee's attention. Oversight of the API gateway and hybrid cloud deployment is assigned to the Model Owner, yet the underlying infrastructure is operated by a third-party provider holding no position in this matrix. Accountability for sub-processor controls is therefore structurally unassigned. Until contractual control obligations are mapped to a named internal owner, the Committee should treat gateway assurance as unverified. This risk is carried forward as GAP-01 in the Section 2 gap analysis.

Section 2—Policy Gap & Compliance Status

1. Responsible AI Policy Gap Analysis

Gap ID	Responsible AI Principle/Standard Requirement	Identified Deficiency (FinanceGuard AI Context)	Severity Rating (High/Med/Low)	Remediation Action Plan
GAP-01	Accountability Goal A1 — Impact assessment Goal A2 — Oversight of significant adverse impacts	Current state: FinanceGuard AI was fine-tuned and promoted to production without a completed Responsible AI Impact Assessment. No approved document identifies stakeholders, intended uses, or foreseeable adverse impacts of automated review on contract approvals and regulatory filings. No AI risk register exists for the deployment, so risks specific to a fine-tuned model handling PII and confidential financial data are neither recorded nor tracked. The third-party cloud provider hosting inference holds no assigned accountability in the governance matrix, leaving oversight of sub-processor controls without a named owner. Desired state: An approved RAI Impact Assessment on file before each material fine-tune, a maintained AI risk register reviewed on a defined cycle, and sub-processor control obligations mapped to a named internal accountable owner and reviewed at every contract renewal.	High	Complete the RAI Impact Assessment for the production model within 30 days; AI Program Lead responsible and Executive Steering Committee accountable, consistent with the Section 1 RACI for model approval. Legal to extract control obligations from the cloud provider agreement into a sub-processor control register with a named internal owner per obligation. Establish an AI risk register covering the fine-tuned model, its data, and its hosting arrangement, reviewed quarterly by the AI Program Lead. Make a current impact assessment and an up-to-date risk register mandatory gate conditions for any subsequent fine-tune.

GAP-02	Privacy & Security Goal PS1 — Privacy Standard compliance Accountability Goal A4 — Data governance and management	Current state: The fine-tuning corpus was assembled from legal and compliance archives containing PII and confidential financial data without documented lineage, minimization, or sanitization records. Prompt and response payloads traverse the internal API gateway to third-party inference endpoints in the hybrid cloud environment, and no evidence demonstrates that session data and provider-side inference logs are purged in line with the corporate retention schedule. Desired state: Full documented lineage for every training and validation set, recorded sanitization and minimization decisions, and demonstrable evidence-backed purge of prompts, responses, and inference logs on the retention schedule.	High	Reconstruct lineage for the current training corpus and record sanitization decisions within 45 days; Model Owner responsible, Cyber Security & Legal accountable. Enable retention tagging and automated purge on gateway and provider-side logs, then evidence one complete purge cycle before the audit window. Where the provider cannot evidence deletion, apply payload tokenization at the gateway so PII never crosses the internal boundary.
GAP-03	Transparency Goal T1 — System intelligibility for decision making Accountability Goal A5 — Human oversight and control	Current state: No model card or documented statement of capabilities, limitations, and out-of-scope uses exists for the fine-tuned model. Compliance analysts and legal reviewers do exercise judgment over outputs, but no attestation is captured, so the organization cannot evidence that a named human reviewed a specific output before it informed a contract approval or regulatory submission. Desired state: A published model card covering intended use, limitations, and known failure modes, and a recorded human review attestation bound to every output used in a contractual or regulatory decision.	Medium	Publish a model card and analyst-facing limitations guidance within 60 days; AI Program Lead responsible. Add a mandatory reviewer attestation field so approval cannot proceed without a named reviewer and timestamp. Rated Medium rather than High because human oversight exists in practice — the deficiency is evidentiary, not an absence of control.

GAP-04	Reliability & Safety Goal RS3 — Ongoing monitoring, feedback, and evaluation Goal RS2 — Failures and remediations	Current state: The internal API gateway records access and transaction metadata, but prompt and response content is not monitored for drift, degradation, or adversarial manipulation, and no adversarial or prompt-injection testing is scheduled after deployment. No failure taxonomy or remediation path exists for incorrect output that has already reached a filing. Desired state: Continuous content-level monitoring with drift and anomaly thresholds, a scheduled adversarial test regime, and a documented failure and remediation procedure covering recall of affected filings.	Medium	Deploy prompt and response monitoring with drift alerting to the AI Program Lead within 60 days. Commission quarterly adversarial and prompt-injection testing; Cyber Security responsible. Define a model failure taxonomy and output recall procedure, and rehearse it once before the audit window.
---------------	--	---	---------------	--

2. ISO/IEC 42001 Compliance Control Matrix Excerpt

Control ID	ISO/IEC 42001 Standard Control Title	Control Intent & Objective	Implementation Status (Implemented/Partial/Gap)	Evidence/Validation Method
A.5.2	Data for AI Systems	Ensure data used to fine-tune and validate FinanceGuard AI is high quality, representative, and collected within documented privacy boundaries appropriate to PII and confidential financial records.	Partial	Data quality and validation reports exist for the fine-tuning corpus, but lineage documentation and sanitization logs are incomplete (GAP-02). Validation: trace a sampled training record back to its source system and sanitization decision.

A.6.2	Logging and Monitoring	Record system inputs, outputs, and runtime behaviour at the internal API gateway to detect anomalies, model drift, and data exfiltration.	Partial	Gateway access and transaction logs are collected and retained; prompt and response content monitoring with drift alerting is not deployed (GAP-04), and purge of logs against the retention schedule is unevidenced (GAP-02). Validation: gateway log export and monitoring dashboard configuration review.
A.7.2	AI System Impact Assessment	Assess and document the consequences of automated document review on internal stakeholders, contract approvals, and regulatory filings.	Gap	No impact assessment has been performed or approved for the production model (GAP-01). No artifact is available for audit. Validation: approved impact assessment signed by the Executive Steering Committee.
A.8.3	Security of AI Systems	Protect the fine-tuned model, its weights, and its inference path from adversarial attack, prompt injection, and unauthorised modification.	Partial	Infrastructure hardening baseline and annual penetration testing cover the gateway and hosting environment; adversarial and prompt-injection testing of the model itself is not scheduled (GAP-04). Validation: penetration test report and adversarial test plan.
A.9.2	AI System Transparency	Document and communicate model capabilities, limitations, and intended use to compliance analysts and	Partial	Analyst training materials and a system user guide are in place; no model card or documented limitations

		legal reviewers who act on its output.		statement exists (GAP-03). Validation: model card review and analyst comprehension attestation.
--	--	--	--	--

Section 3—Audit Readiness Assessment

1. SOC 2 Evidence Review Summary

Control ID	Trust Services Criteria (TSC)	Control Description (FinanceGuard AI Context)	Provided Audit Artifact/ Evidence	Evidence Evaluation & Status (Pass/Partial/ Fail)
CC6.1	Security: Access Transmission	The internal API gateway restricts model access to authorized compliance and legal user groups, encrypting PII/financial data in transit.	API gateway role-based access control (RBAC) policy restricting model access to compliance and legal user groups; TLS 1.2+ configuration for data in transit; current access control list export.	Partial Access restriction and transport encryption are configured and documented. However, access events are captured only as metadata — content-level monitoring is not deployed (ISO A.6.2 — Partial, GAP-04) and the access path has not been adversarially tested (ISO A.8.3 — Partial, GAP-04). Operating effectiveness over a sustained review period cannot yet be demonstrated to an external auditor.
CC6.3	Security: Perimeter Defense	Hybrid cloud infrastructure endpoints hosting the fine-tuned LLM are hardened against unauthorized access and prompt injection.	Infrastructure hardening baseline for the hybrid cloud hosting environment; most recent annual network-layer penetration test report.	Partial Perimeter hardening and network-layer penetration testing are current and satisfactory. No prompt-injection or adversarial testing specific to the fine-tuned model has been performed (ISO A.8.3 — Partial, GAP-04), leaving the model-specific portion of this criterion unevidenced.
CC7.1	Confidentiality: Data Retention & Disposal	Confidential financial documents and temporary session data processed by	Corporate data retention and disposal schedule	Fail The retention schedule exists as policy, but no

		the LLM are purged or encrypted according to corporate retention schedules.	(policy document). No artifact was available evidencing purge of gateway session data or deletion of provider-side inference logs.	evidence demonstrates that session data or third-party inference logs are actually purged in line with it (ISO A.5.2/A.6.2 — Partial, GAP-02 — High severity). For this specific criterion, evidence of deletion is entirely absent rather than incomplete, which is a Fail regardless of the broader controls' Partial rating.
--	--	---	--	---

2. CISO Executive Recommendation

To: Chief Information Security Officer (CISO)

From: AI Governance Program Lead

Date: July 8, 2026

Subject: SOC 2 Audit Readiness Assessment & Recommendations for FinanceGuard AI

Recommendation: No-Go. I recommend deferring the external audit by one quarter.

This assessment did not find a system with scattered weaknesses. It found one whose controls were built for infrastructure and never extended to the model itself. We can evidence who reached the gateway and how the channel was encrypted. We cannot evidence what the model received, what it returned, or whether that content was ever destroyed.

That single distinction is our exposure. Confidential financial documents and PII cross the internal boundary for third-party inference, and we hold no deletion attestation from the provider. We therefore cannot state, under examination, how long client PII persists outside our control or who has held it. Entering fieldwork in this position converts an internal finding into a qualified opinion on Confidentiality — and because these outputs inform regulatory submissions, it invites a supervisory question we cannot presently answer.

Residual risk is concentrated rather than diffuse, which is what makes deferral credible instead of evasive. Three milestones close it, in priority order:

1. Obtain provider deletion attestation and evidence one complete purge cycle — 45 days. This alone resolves the Confidentiality failure.
2. Complete the AI impact assessment and stand up the risk register — 30 days, and the cheapest of the three.

3. Commission adversarial testing and deploy content-level monitoring — 60 days.

Ninety days makes this system auditable. Ninety days of fieldwork now does not.

Section 4—Policy Statements & Exception Record

1. AI Model Security & Monitoring Policy Statements

Policy ID	Policy Statement	ISO/IEC 42001 Clause or Control Enforced	Risk/Gap Addressed	Enforcement & Monitoring Mechanism
POL-01	Impact Assessment & Risk Register Gate No fine-tuned model shall be promoted to, or retained in, production use in support of contract approval or regulatory filing without a current approved AI impact assessment and a corresponding entry in the AI risk register. Both artifacts shall be re-performed on any material fine-tune, change of training corpus, or change of hosting arrangement, and reviewed no less than quarterly.	Clause 6.1.2 — AI Risk Assessment; A.7.2 — AI System Impact Assessment	GAP-01 (High). Both controls tagged Gap in the Section 2 control matrix.	Release gate operated by the AI Program Lead; Executive Steering Committee approval recorded before release. Transitional provision: systems already in production at adoption shall achieve compliance within 30 days, per the Section 3 remediation schedule; thereafter absence of either artifact suspends production use. Verified at quarterly governance review.
POL-02	Sub-Processor Accountability Every control obligation arising from the third-party cloud hosting arrangement shall be recorded in a sub-processor control register and assigned to a named internal accountable owner. No inference workload shall be placed with, or retained on, a provider whose control obligations are unassigned or unverified.	Clause 6.1.2 — AI Risk Assessment (hosting arrangement risk); published ISO/IEC 42001 A.10 — Third-Party & Customer Relationships, not represented in the Section 2 matrix	GAP-01 (High); accountability gap raised in the Section 1 executive sign-off memo.	Legal maintains the register; Executive Steering Committee accountable. Register reviewed at every contract renewal and before any new provider is engaged.
POL-03	Data Boundary, Lineage & Disposal PII and confidential financial data shall not traverse the internal API gateway to third-party inference endpoints in the hybrid cloud environment unless tokenized or otherwise de-identified, or covered by a current provider deletion attestation. All training and validation datasets shall carry documented lineage and sanitization records, and all prompts, responses, and inference logs shall be purged in accordance with the corporate retention schedule with deletion evidence retained.	A.5.2 — Data for AI Systems; A.6.2 — Logging and Monitoring	GAP-02 (High); SOC 2 CC7.1 rated Fail in Section 3.	Cyber Security & Legal accountable. Gateway data-loss-prevention policy to be configured to block untokenized payloads within 45 days, per the GAP-02 remediation plan; it is not yet in force. Purge evidence sampled quarterly thereafter; provider attestation reviewed annually.
POL-04	Adversarial & Prompt-Injection Testing	A.8.3 — Security of AI Systems	GAP-04 (Medium); SOC 2 CC6.3 rated	Cyber Security responsible for commissioning tests; results reported to the AI Program Lead.

	The fine-tuned model, its weights, and its inference path shall undergo adversarial and prompt-injection testing at least quarterly and before any material change. Findings rated high or above shall be remediated, or formally excepted under the exception record below, before continued production use.		Partial in Section 3.	Unremediated high findings escalate to the Executive Steering Committee within 10 business days.
POL-05	Continuous Monitoring & Failure Response Prompt and response content shall be monitored for drift, degradation, and anomalous behaviour against defined thresholds, with alerting to the AI Program Lead. A documented failure taxonomy and output recall procedure shall be maintained and rehearsed at least annually, covering withdrawal of affected contract approvals and regulatory submissions.	A.6.2 — Logging and Monitoring	GAP-04 (Medium); SOC 2 CC6.1 rated Partial — logging is metadata-only.	AI Program Lead accountable, consistent with the Section 1 RACI. Monthly monitoring report to the Executive Steering Committee; recall procedure rehearsal evidenced annually.
POL-06	Transparency & Human Accountability of Output A current model card documenting capabilities, limitations, and out-of-scope uses shall be published and made available to all compliance and legal users. No FinanceGuard AI output shall inform a contract approval or regulatory submission without a recorded attestation naming the reviewing analyst and the date of review.	A.9.2 — AI System Transparency	GAP-03 (Medium).	AI Program Lead publishes and reviews the model card semi-annually. Workflow control blocks approval where the attestation field is absent; exceptions sampled monthly.

2. Policy Exception Decision Record

Field	Entry
Exception ID	EXC-01
Date raised	8 July 2026
Raised by	Model Owner / Business Sponsor
Policy requirement not met	POL-04 — Adversarial & Prompt-Injection Testing. Enforces ISO/IEC 42001 A.8.3 (Security of AI Systems); evidences SOC 2 CC6.3. The policy requires quarterly adversarial and prompt-injection testing of the fine-tuned model, its weights, and its inference path, with high-rated findings remediated before continued production use.
Why the requirement cannot currently be met	No internal capability exists to adversarially test a fine-tuned LLM. Specialist vendor procurement, clearance, and a data-handling agreement cannot complete within the current quarter; the earliest credible first test date is 60 days from approval. Suspending FinanceGuard AI in the interim would return the full monthly contract review volume to manual processing during the regulatory filing period.

Risk-based rationale	The underlying deficiency is GAP-04, rated Medium — not one of the two High findings. A.8.3 is rated Partial rather than Gap in the Section 2 matrix: infrastructure hardening and network-layer penetration testing are current and evidenced, so the untested surface is the model layer specifically, not the perimeter. No prompt-injection incident has been identified in gateway logs to date. The residual exposure is therefore bounded. It is not the deletion-evidence failure at CC7.1 that is the determinative basis for the Section 3 No-Go recommendation, though it shares that recommendation's wider concern about content-level visibility.
Compensating controls in force for the exception period	1. Gateway input filtering and payload size limits applied to every inference request. 2. All outputs remain subject to human review under POL-06 before informing any contract approval or regulatory submission — no autonomous filing path exists. 3. Weekly manual review of gateway anomaly logs by Cyber Security. 4. Model rollback to the prior checkpoint available on demand — an infrastructure control only; it does not constitute the output recall procedure that POL-05 still requires.
Residual risk rating	Medium — accepted for the duration of the exception period only.
Approving governance role (Section 1 RACI)	Executive Steering Committee, designated Accountable for "Exception Identification & Framework Mitigation." AI Program Lead responsible for maintaining this record and reporting status; Cyber Security & Legal consulted.
Decision	APPROVED — time-limited and conditional.
Conditions of approval	Vendor engaged within 30 days. First adversarial test completed and reported within 60 days. Any high-rated finding remediated within 15 business days of report, failing which this exception lapses immediately and FinanceGuard AI is withdrawn from regulatory filing support.
Expiry date	6 September 2026 (60 days from approval). Automatic lapse on expiry. No extension without a fresh Executive Steering Committee decision.
Review and escalation	Status reported at each monthly governance review. Escalation to the CISO — the executive owner of the Cyber Security & Legal function designated in the Section 1 RACI — and thereafter to the Executive Steering Committee if the 30-day vendor engagement milestone is missed.
Related request refused under this review	A parallel request to except POL-03 (Data Boundary, Lineage & Disposal), permitting untokenized PII to continue reaching third-party inference endpoints pending provider attestation, was DENIED. That deficiency is GAP-02 (High) and carries the CC7.1 Fail rating; it is the exposure on which the Section 3 No-Go rests. Granting it would except the organization from the very control the external audit will test. Remediation, not exception, is the only available path.

Appendix A—ISO/IEC 42001 Compliance Control Matrix

Control Reference	ISO/IEC 42001 Control Name & Domain	Control Objective & System Application	Implementation Status (Implemented/Partial/Gap)	Audit Evidence/Validation Artifact
Clause 6.1.2	AI Risk Assessment	Identify, analyze, and evaluate risks specific to the fine-tuned LLM processing confidential PII and financial data.	Gap Traced to GAP-01	Algorithmic impact assessment (AIA) or AI risk register.
A.5.2	Data for AI Systems	Ensure data used for fine-tuning and validation is high quality, representative, and collected with appropriate data privacy boundaries.	Partial Traced to GAP-02	Data lineage documentation and data sanitization logs.
A.6.2	Logging and Monitoring	Record system inputs, outputs, and runtime behaviors via the internal API gateway to detect anomalies or data exfiltration.	Partial Traced to GAP-02, GAP-04	API gateway logs, prompt/response monitoring dashboard configs.
A.7.2	AI System Impact Assessment	Assess the potential consequences of the automated document review system on internal stakeholders and regulatory filings.	Gap Traced to GAP-01	Documented business impact and bias/fairness evaluation reports.

A.8.3	Security of AI Systems	Protect the fine-tuned LLM infrastructure from adversarial attacks, prompt injection, and unauthorized weights modification.	Partial Traced to GAP-04	Vulnerability assessment reports and API access control policies.
A.9.2	AI System Transparency	Provide clear documentation and explanations of the model's capabilities, limitations, and intended use to internal analysts.	Partial Traced to GAP-03	Model cards, system user manuals, and training materials.

Status Definitions:

1. **Implemented:** The control is fully functional, documented, and actively producing evidence (for example, active API logging).
2. **Partial:** The control is partially designed or active but lacks complete documentation, enforcement, or consistent evidence generation.
3. **Gap:** The control is missing entirely or fundamentally insufficient, creating immediate regulatory or operational risk.